

Security Scan Report

Target: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main

Generated: 2026-04-19T16:33:01.821049Z

Findings

[Severity 5] java.spring.security.injection.tainted-file-path.tainted-file-path

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\backend\src\main\java\com\acme\foo\FileUploadApi.java (line 38)

Risk Score: 36.05

How To Fix (Mitigation):

Review the flagged code and apply the principle of least privilege.

Validate and sanitize all user inputs at the application boundary.

Follow secure coding guidelines for your language/framework.

Consult OWASP guidance for this vulnerability category: <https://owasp.org/www-project-top-ten/>

[Severity 5] java.spring.security.injection.tainted-file-path.tainted-file-path

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\backend\src\main\java\com\acme\foo\FileUploadApi.java (line 41)

Risk Score: 36.05

How To Fix (Mitigation):

Review the flagged code and apply the principle of least privilege.

Validate and sanitize all user inputs at the application boundary.

Follow secure coding guidelines for your language/framework.

Consult OWASP guidance for this vulnerability category: <https://owasp.org/www-project-top-ten/>

[Severity 3] javascript.express.security.audit.xss.direct-response-write.direct-response-write

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js (line 216)

Risk Score: 2.97

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.

Use context-aware output encoding (HTML, JS, URL, CSS).

CosmoGrepperAI - Advanced Security Scanner

Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.injection.raw-html-format.raw-html-format

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 271)
Risk Score: 9.09

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.injection.raw-html-format.raw-html-format

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 360)
Risk Score: 9.09

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.injection.raw-html-format.raw-html-format

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 380)
Risk Score: 9.09

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.injection.raw-html-format.raw-html-format

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 381)
Risk Score: 9.09

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.

CosmoGrepperAI - Advanced Security Scanner

Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.injection.raw-html-format.raw-html-format

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 385)

Risk Score: 9.09

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.audit.xss.direct-response-write.direct-response-write

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 453)

Risk Score: 2.97

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.audit.xss.direct-response-write.direct-response-write

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 703)

Risk Score: 2.97

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.audit.xss.direct-response-write.direct-response-write

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 714)

Risk Score: 2.97

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

CosmoGrepperAI - Advanced Security Scanner

[Severity 3] javascript.express.security.audit.xss.direct-response-write.direct-response-write

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 743)

Risk Score: 2.97

How To Fix (Mitigation):

Escape all user-supplied data before rendering in HTML.
Use context-aware output encoding (HTML, JS, URL, CSS).
Implement Content-Security-Policy (CSP) headers.
Use framework auto-escaping (e.g., Jinja2 autoescape=True).

[Severity 3] javascript.express.security.express-insecure-template-usage.express-insecure-templ

File: C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\index.js
(line 790)

Risk Score: 9.91

How To Fix (Mitigation):

Review the flagged code and apply the principle of least privilege.
Validate and sanitize all user inputs at the application boundary.
Follow secure coding guidelines for your language/framework.
Consult OWASP guidance for this vulnerability category: <https://owasp.org/www-project-top-ten/>

[Severity 3] html.security.plaintext-http-link.plaintext-http-link

File:
C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\chat-ui.html (line 265)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] html.security.plaintext-http-link.plaintext-http-link

File:
C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\chat-ui.html (line 266)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

CosmoGrepperAI - Advanced Security Scanner

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\chat-ui.html (line 267)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\chat-ui.html (line 272)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\dotprop.html (line 102)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\dotprop.html (line 103)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.

CosmoGrepperAI - Advanced Security Scanner

Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\dotpr
op.html (line 104)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\dotpr
op.html (line 109)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\ejs.h
tml (line 24)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\hand
lebars.html (line 23)

CosmoGrepperAI - Advanced Security Scanner

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\index.html (line 100)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\index.html (line 101)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\index.html (line 102)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

CosmoGrepperAI - Advanced Security Scanner

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\index.html (line 107)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\lodash.html (line 103)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\lodash.html (line 104)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\lodash.html (line 105)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.

CosmoGrepperAI - Advanced Security Scanner

Ensure TLS certificates are valid and up to date.

[Severity 3] **html.security.plaintext-http-link.plaintext-http-link**

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\loda
sh.html (line 110)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.

Use HSTS (HTTP Strict Transport Security) headers.

Redirect all HTTP requests to HTTPS.

Ensure TLS certificates are valid and up to date.

[Severity 3] **html.security.plaintext-http-link.plaintext-http-link**

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\mark
down.html (line 103)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.

Use HSTS (HTTP Strict Transport Security) headers.

Redirect all HTTP requests to HTTPS.

Ensure TLS certificates are valid and up to date.

[Severity 3] **html.security.plaintext-http-link.plaintext-http-link**

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\mark
down.html (line 104)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.

Use HSTS (HTTP Strict Transport Security) headers.

Redirect all HTTP requests to HTTPS.

Ensure TLS certificates are valid and up to date.

[Severity 3] **html.security.plaintext-http-link.plaintext-http-link**

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\mark
down.html (line 105)

Risk Score: 3.24

CosmoGrepperAI - Advanced Security Scanner

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:
C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\mark
down.html (line 110)
Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:
C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\pug.
html (line 102)
Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:
C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\pug.
html (line 103)
Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] [html.security.plaintext-http-link.plaintext-http-link](#)

File:

CosmoGrepperAI - Advanced Security Scanner

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\pug.html (line 104)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] html.security.plaintext-http-link.plaintext-http-link

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\pug.html (line 109)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] html.security.plaintext-http-link.plaintext-http-link

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\templates\serialize.html (line 24)

Risk Score: 3.24

How To Fix (Mitigation):

Enforce HTTPS for all communications.
Use HSTS (HTTP Strict Transport Security) headers.
Redirect all HTTP requests to HTTPS.
Ensure TLS certificates are valid and up to date.

[Severity 3] java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\xz-java-malicious\src\main\java\org\tukaani\xz\XZOutputStream.java (line 290)

Risk Score: 5.35

How To Fix (Mitigation):

Replace weak hashing algorithms (MD5, SHA1) with SHA-256 or stronger.
For passwords, use bcrypt, scrypt, or Argon2 with proper salt.
Use TLS 1.2+ for data in transit and AES-256 for data at rest.
Never implement custom cryptographic algorithms.

CosmoGrepperAI - Advanced Security Scanner

[Severity 5] SCA: body-parser@1.20.2 (Max CVSS: 7.5)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `body-parser` (version 1.20.2) contains known public vulnerabilities with a maximum CVSS context score of **7.5**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `body-parser` to the latest secure version in `package.json`.
Transitive Dependency Note: If `body-parser` is imported indirectly by another package, you may need to force a resolution override:
- **Node** (`package.json`): Use `resolutions` or `overrides` to pin the child version.
- **Java** (`pom.xml`): Pin the secure version in a `<dependencyManagement>` block or add an explicit exclude.
- **Python** (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: dot-prop@4.2.0 (Max CVSS: 9.8)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `dot-prop` (version 4.2.0) contains known public vulnerabilities with a maximum CVSS context score of **9.8**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `dot-prop` to the latest secure version in `package.json`.
Transitive Dependency Note: If `dot-prop` is imported indirectly by another package, you may need to force a resolution override:
- **Node** (`package.json`): Use `resolutions` or `overrides` to pin the child version.
- **Java** (`pom.xml`): Pin the secure version in a `<dependencyManagement>` block or add an explicit exclude.
- **Python** (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: ejs@2.6.1 (Max CVSS: 9.8)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 12.24

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `ejs` (version 2.6.1) contains known public vulnerabilities with a maximum CVSS context score of **9.8**. Operating components with known vulnerabilities exposes the application

CosmoGrepperAI - Advanced Security Scanner

supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `ejs` to the latest secure version in `package.json`.
Transitive Dependency Note: If `ejs` is imported indirectly by another package, you may need to force a resolution override.
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 3] SCA: express@4.18.2 (Max CVSS: 6.1)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 7.34

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `express` (version 4.18.2) contains known public vulnerabilities with a maximum CVSS context score of **6.1**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `express` to the latest secure version in `package.json`.
Transitive Dependency Note: If `express` is imported indirectly by another package, you may need to force a resolution override.
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: handlebars@4.0.14 (Max CVSS: 9.8)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 12.24

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `handlebars` (version 4.0.14) contains known public vulnerabilities with a maximum CVSS context score of **9.8**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `handlebars` to the latest secure version in `package.json`.
Transitive Dependency Note: If `handlebars` is imported indirectly by another package, you may need to force a resolution override.
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

CosmoGrepperAI - Advanced Security Scanner

[Severity 5] SCA: ip@1.1.8 (Max CVSS: 9.8)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 6.8

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `ip` (version 1.1.8) contains known public vulnerabilities with a maximum CVSS context score of **9.8**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `ip` to the latest secure version in `package.json`.
Transitive Dependency Note: If `ip` is imported indirectly by another package, you may need to force a resolution override:
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: lodash@4.17.11 (Max CVSS: 9.8)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 12.24

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `lodash` (version 4.17.11) contains known public vulnerabilities with a maximum CVSS context score of **9.8**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `lodash` to the latest secure version in `package.json`.
Transitive Dependency Note: If `lodash` is imported indirectly by another package, you may need to force a resolution override:
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: marked@0.3.5 (Max CVSS: 7.5)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `marked` (version 0.3.5) contains known public vulnerabilities with a maximum CVSS context score of **7.5**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

CosmoGrepperAI - Advanced Security Scanner

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `marked` to the latest secure version in `package.json`.
Transitive Dependency Note: If `marked` is imported indirectly by another package, you may need to force a resolution override:
- **Node** (`package.json`): Use `resolutions` or `overrides` to pin the child version.
- **Java** (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
- **Python** (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: serialize-javascript@2.1.1 (Max CVSS: 7.5)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `serialize-javascript` (version 2.1.1) contains known public vulnerabilities with a maximum CVSS context score of **7.5**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `serialize-javascript` to the latest secure version in `package.json`.
Transitive Dependency Note: If `serialize-javascript` is imported indirectly by another package, you may need to force a resolution override:
- **Node** (`package.json`): Use `resolutions` or `overrides` to pin the child version.
- **Java** (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
- **Python** (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: trim-newlines@4.0.0 (Max CVSS: 7.5)

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `trim-newlines` (version 4.0.0) contains known public vulnerabilities with a maximum CVSS context score of **7.5**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `trim-newlines` to the latest secure version in `package.json`.
Transitive Dependency Note: If `trim-newlines` is imported indirectly by another package, you may need to force a resolution override:
- **Node** (`package.json`): Use `resolutions` or `overrides` to pin the child version.
- **Java** (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
- **Python** (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.

[Severity 5] SCA: ws@6.2.1 (Max CVSS: 8.7)

CosmoGrepperAI - Advanced Security Scanner

File:

C:\Users\appse\Documents\TestField\Damn-vulnerable-sca-main\Damn-vulnerable-sca-main\package.json
(line 1)

Risk Score: 4.0

Why This Code Is Vulnerable:

Why This Component Is Vulnerable: The package `ws` (version 6.2.1) contains known public vulnerabilities with a maximum CVSS context score of **8.7**. Operating components with known vulnerabilities exposes the application supply chain to public exploit methods and remote code execution if unchecked.

How To Fix (Mitigation):

How To Fix (Mitigation): Update the package `ws` to the latest secure version in `package.json`.
Transitive Dependency Note: If `ws` is imported indirectly by another package, you may need to force a resolution override:
Node (`package.json`): Use `resolutions` or `overrides` to pin the child version.
Java (`pom.xml`): Pin the secure version in a `` block or add an explicit exclude.
Python (`requirements.txt`): Explicitly add the secured version of the sub-dependency above the top-level package.